

Professional AC Core Cutting Business Website

Security, Quality & Operations Document • v1.0 • Production Baseline

AREA	PRODUCTION POLICY
Security	Protect public forms, customer lead data, secrets and infrastructure
Quality	Prevent defects through validation, testing, review and release gates
Operations	Run predictable local → staging → production workflows
Availability	Keep Call, WhatsApp and enquiry paths reliable
Data	Minimize personal data and protect operational records
Monitoring	Observe application health, lead delivery, performance and errors
Recovery	Maintain backups, rollback/recovery procedures and incident response

Operating principle: ship only verified content, secure server-side boundaries, tested conversion paths and a production environment that can be observed and recovered.

This document is the operational control layer for the project's existing UI/UX, App Flow, Backend Schema, Database Schema and System Architecture specifications.

1. Security Objectives

- Protect customer enquiry information from unauthorized access.
- Keep database credentials, API keys and private integration secrets outside browser bundles.
- Validate and sanitize every untrusted server-side input.
- Reduce automated spam and abusive traffic on lead endpoints.
- Provide safe user-facing errors without leaking internal implementation details.
- Use HTTPS for production traffic.
- Restrict administrative and infrastructure access using least privilege.
- Minimize stored personal information and unnecessary logs.
- Keep dependencies and deployment configuration maintained.
- Preserve reliable direct contact paths even when non-critical integrations fail.

Security boundary

BROWSER / UNTRUSTED TRAFFIC → HTTPS → SERVER VALIDATION → SPAM CONTROLS → APPLICATION LOGIC → DATABASE / INTEGRATIONS

The browser is never trusted. Client-side validation is a usability feature; server-side validation is the security boundary.

2. Threat & Risk Model

RISK	EXAMPLE	PRIMARY CONTROL	PRIORITY
Form abuse	Bot floods quote endpoint	Rate limiting + honeypot/CAPTCHA-equivalent	Critical
Injection	Malicious form/query input	Parameterized queries + server validation	Critical
Secret exposure	API/DB key shipped to browser	Server-only environment secrets	Critical
Data exposure	Lead records publicly accessible	Server-only DB access + authorization	Critical
XSS	Unsafe customer input rendered	Output encoding + sanitization	High
Dependency issue	Vulnerable package	Dependency review/update process	High
Broken integration	Email/CRM unavailable	Persistence + retry/alert strategy	High
Bad content	Fake review/service claim	Owner approval + publishing controls	High
SEO abuse	Fake location pages	Genuine service-area governance	Medium
Operational failure	Bad migration/deployment	Preview + backup + smoke tests	High

The project is a lead-generation site rather than an account/payment platform, so the highest-risk surface is the public enquiry path and the protection of lead data.

3. Application Security Controls

CONTROL	REQUIRED BEHAVIOR	VERIFICATION
HTTPS	Production forms and site traffic use HTTPS	Production smoke test
Input validation	Validate type, length, required fields and allowed values server-side	Automated tests
Sanitization	Treat all user-provided strings as untrusted	Security review
SQL safety	Parameterized queries/safe ORM only	Code review/static analysis
Rate limiting	Throttle repeated enquiry requests	Abuse test
Bot protection	Honeypot and/or CAPTCHA-equivalent when required	Form test
Error handling	Generic public error; detailed server diagnostics only	Failure injection
Secure headers	Use appropriate production security headers	Header scan/review
Secrets	No secrets in client code, repository or public config	Build/repository inspection
Authorization	Any future admin endpoints require authenticated access	Permission test

Never depend on hidden fields, disabled buttons or client-side rules as security controls.

4. Enquiry Security

The quote form is the primary untrusted write path.

QUOTE FORM → POST /api/enquiries → SCHEMA CHECK → NORMALIZE → RATE LIMIT → BOT CHECK → FK CHECK → INSERT → DELIVERY → SAFE RESPONSE

Required checks

- Name: required, bounded length, normalized whitespace.
- Phone: required, bounded length and validated format.
- WhatsApp preference: boolean only.
- Service: validate against an existing allowed service record when supplied.
- Location: bounded untrusted text; never automatically creates a public service area.
- Message: optional but bounded to prevent oversized requests.
- Status: server-controlled enum; never trust client-provided status.
- Source page: server-derived or strictly validated, not a free-form operational command.

Abuse response

Repeated or clearly automated requests should be throttled/rejected without revealing detailed anti-abuse rules. Operational logs may record enough information to investigate the incident without storing unnecessary personal content.

5. Data Protection & Privacy

DATA	ACCESS	POLICY
Business public data	Public	Only verified owner-approved information
Services / FAQs / areas	Public	Publish only approved content
Gallery	Public	Real approved work/media
Reviews	Public	Approved and appropriately attributed
Enquiry name/phone/message	Restricted	Business/server operations only
Analytics metadata	Limited	No unnecessary personal data
Credentials/secrets	Highly restricted	Secret manager/environment only
Backups	Restricted	Protected storage + controlled access

Data minimization

- Collect only what is needed to respond to a customer.
- Do not collect account passwords, payment details or unrelated sensitive information in the MVP.
- Do not place lead phone numbers or message content inside analytics metadata.
- Do not log raw form payloads by default.
- Define a practical retention period for enquiries before production launch.

6. Infrastructure & Access Security

- Use separate local, staging and production environments.
- Use separate database credentials per environment.
- Runtime credentials should have only the permissions they need.
- Migration/admin credentials should not be used as normal runtime credentials.
- Protect hosting, database, repository and deployment accounts with strong authentication.
- Review access when team members or service providers change.
- Do not commit .env files containing secrets.
- Do not expose database ports publicly unless required by a protected architecture.
- Keep production backups protected from the application runtime role.
- Review third-party integrations before enabling them in production.

Secret classification

SECRET	CLIENT EXPOSED?	STORAGE
Database URL/password	No	Deployment secret/environment
Email/CRM API key	No	Deployment secret/environment
Analytics private key	No	Server secret if applicable
Public business phone	Yes	Public content/config
Public WhatsApp link	Yes	Public content/config

7. Quality Engineering Strategy

Quality is treated as a release process, not only a final test.

QUALITY LAYER	WHAT IS CHECKED
Content quality	Business facts, service descriptions, claims, reviews, areas
Component quality	Reusable UI states, empty/loading/error behavior
Functional quality	Navigation, CTAs, forms, gallery, FAQ, map links
API quality	Validation, rate limiting, success/failure contracts
Database quality	Constraints, migrations, indexes, seed integrity
Responsive quality	Mobile-first layouts and desktop adaptation
Accessibility	Semantic structure, labels, keyboard access, focus, contrast
SEO quality	Metadata, canonical, sitemap, robots, structured data
Performance	Images, JS, fonts, rendering, Core Web Vitals
Security quality	Secrets, headers, input handling, dependency health
Browser quality	Current major browsers and common mobile environments

The project's QA scope includes functional, responsive, browser, accessibility, SEO, performance, security and content checks.

8. Quality Gates

GATE	ENTRY CONDITION	PASS CRITERIA
G1 — Development	Feature implemented	Build/type checks pass; no known blocker
G2 — Integration	Feature connected	API/data/error states work
G3 — Preview	Candidate release deployed	Responsive + browser + accessibility + SEO checks pass
G4 — Security	Release candidate	No critical secret/input/security issue
G5 — Production	Approved release	Smoke tests pass after deployment

Release blockers

- Broken Call, WhatsApp or quote conversion path.
- Secret exposed to browser/repository.
- Unvalidated server-side enquiry input.
- Critical build/runtime error.
- Fake/unapproved customer reviews or business claims.
- Broken public route or missing core asset.
- Production migration failure or unverified database state.

9. Testing Matrix

TEST TYPE	MINIMUM TESTS
Unit	Validation schemas, formatting/normalization, business rules
Integration	Enquiry endpoint → DB; content queries → pages
E2E	Home → service → quote; Call/WhatsApp; contact submission
Responsive	Mobile, tablet and desktop breakpoints
Accessibility	Keyboard navigation, labels, focus, headings, contrast, alt text
SEO	Metadata, canonical, sitemap, robots, structured data
Performance	Image loading, JS size, server response, Core Web Vitals
Security	Input abuse, rate limiting, secret scan, headers, authorization
Browser	Chrome/Edge/Safari/Firefox as applicable
Recovery	DB failure, external integration failure, bad form data

Testing should be repeatable in preview/staging before production approval.

10. Content Quality Operations

Content is part of system quality because the site is a local trust and lead-generation product.

- Business name, phone, WhatsApp, city, address and hours must be verified.
- Services must reflect what the business actually performs.
- Service areas must be genuine.
- Gallery must use real work images where represented as completed work.
- Reviews must be approved and appropriately attributed.
- Claims such as years of experience, equipment capability or guarantees require owner verification.
- Do not publish stable pricing unless intentionally approved.
- Every informative image requires useful alt text.
- Every public service page should have unique, accurate metadata.

Content publishing workflow

DRAFT → OWNER REVIEW → FACT CHECK → SEO/ACCESSIBILITY CHECK → PUBLISH → PERIODIC REVIEW

11. Production Operations

OPERATION	PROCEDURE
Deployment	Build → test → preview → approve → production
Database migration	Backup/check → migration → verify → smoke test
Content change	Edit → review → publish → verify public page
Dependency update	Update → tests → security/build review → preview
Lead delivery	Monitor persistence and email/CRM delivery failures
Incident	Detect → contain → diagnose → recover → document
Backup	Automated protected backups according to hosting/database capability
Access review	Periodic review of deployment/database/admin permissions

Operational ownership

Even for a small business website, define who owns: production deployment, business-content approval, lead follow-up, domain/DNS, hosting, database, backups and third-party accounts.

12. Monitoring & Observability

SIGNAL	MONITOR
Availability	HTTP uptime, failed requests
Application errors	Server exceptions, route failures
Lead health	Enquiry creation count, failed submissions, delivery failures
Performance	Response time, Core Web Vitals, asset weight
Database	Connection errors, query latency, storage/backups
Security	Rate-limit spikes, suspicious traffic, dependency/security alerts
SEO	Broken links, sitemap availability, indexing/schema issues

Alert priorities

P1: quote path unavailable / production outage / data exposure

P2: lead delivery degraded / major route failure

P3: non-critical UI, content or performance degradation

13. Incident Response

Recommended incident lifecycle:

DETECT → CLASSIFY → CONTAIN → INVESTIGATE → RECOVER → VERIFY → DOCUMENT → PREVENT RECURRENCE

SEVERITY	EXAMPLES	FIRST ACTION
P1 Critical	Site down, lead path unavailable, suspected data exposure	Contain immediately; owner/developer escalation
P2 High	Lead delivery failing, major service page broken	Mitigate and restore within operational priority
P3 Medium	Non-critical defect or degraded performance	Schedule fix and monitor
P4 Low	Minor UI/content issue	Include in normal maintenance

Post-incident

- Record what happened and when.
- Identify affected functionality/data.
- Confirm recovery with a targeted smoke test.
- Identify root cause and contributing factors.
- Create a prevention task if a process/control was missing.

14. Backup, Recovery & Rollback

ASSET	RECOVERY REQUIREMENT
Database	Protected backups + tested restore procedure
Source code	Version control + protected remote repository
Media	Original/optimized asset backup or durable media storage
Environment config	Document required variables; store secrets securely
Migrations	Version-controlled and reproducible
Deployment	Known-good release available for rollback

Recovery sequence

1. Stop further damage → 2. identify last known-good state → 3. restore/rollback → 4. validate database/application → 5. test enquiry path → 6. reopen traffic → 7. document incident.

Destructive schema changes should not be deployed without a backup and recovery plan.

15. Change Management

CHANGE	REQUIRED REVIEW
UI/content	Visual + content + responsive review
Database schema	Migration review + backup/recovery consideration
API/form	Validation/security + integration tests
SEO	Metadata/canonical/sitemap impact
Third-party script	Performance/privacy/security review
Dependency	Build/test/security review
Infrastructure	Environment/secret/availability review

Small changes can have system-wide effects: a phone-number change affects header, hero, sticky CTA, contact page, structured data and analytics attribution. Use a single verified business data source wherever possible.

16. Operational Checklists

Pre-deployment

- Production build passes.
- No secret is committed or client-exposed.
- Database migrations reviewed.
- Preview deployment tested.
- Call/WhatsApp/quote paths tested.
- Forms validated and rate-limited.
- Core public routes checked.
- SEO files and metadata checked.
- Images optimized and alt text reviewed.
- Accessibility smoke test completed.

Post-deployment

- Open homepage and primary service page.
- Test Call/WhatsApp links.
- Submit a controlled test enquiry if safe.
- Verify enquiry persistence/delivery.
- Check server/application logs.
- Check analytics conversion events.
- Check production domain/HTTPS.
- Confirm monitoring is active.

17. Security & Quality Review Cadence

CADENCE	REVIEW
Every deployment	Build, smoke test, conversion paths, secrets
Weekly / operationally appropriate	Lead delivery, uptime/errors, content issues
Monthly	Dependencies, access, backups, analytics, performance
Quarterly / business-defined	Service areas, reviews, business details, retention
After incident	Root cause, controls and recovery process

Exact cadence may be adjusted to the business's traffic and operational capacity. The key requirement is that ownership and repeatability are explicit.

18. Definition of Production Ready

- Security controls are implemented at the server boundary.
- No secrets are exposed in client code.
- Enquiry endpoint is validated and protected against abuse.
- Database access is restricted and migrations are reproducible.
- Backups/recovery expectations are established.
- All core conversion paths work on mobile and desktop.
- Public content is verified and approved.
- Accessibility and responsive checks are completed.
- SEO metadata, sitemap, robots and structured data are valid.
- Performance has been reviewed and major bottlenecks addressed.
- Monitoring/error visibility is available.
- Production smoke tests pass.
- An owner is identified for business content and lead follow-up.